

Terraform Security Notes

Mohammad Fozouni (Ph.D.)

MLSECOPS IN ACTION COURSE



HashiCorp

Terraform

دو مورد حساس وجود دارد

فایل

terraform.tfstate

مدیریت secrets در ترافورم

فایل

terraform.tfstate



نمایی زیبا و دلربا از فایل terraform.tfstate

```
"image_id": "793cdb82-c731-4aeb-808d-19da98525a02",  
"init_script": null,  
"name": "Terraforms9",  
"networks": [  
  {  
    "ip": "10.255.255.150",  
    "is_public": false,  
    "network_id": "9ad6bd38-a791-481a-be5e-8b09f107fcc0",  
    "port_id": "303779b3-15f0-4aaa-9539-724818b94266",  
    "port_security_enabled": true,  
    "subnet_id": "cd9f8906-c0a8-44fa-af89-18a6294d60ec"  
  }  
],  
"password": "pNxRvPMJeI",  
"region": "ir-thr-bal",  
"revert_to": null,  
"security_groups": [  
  "5f38ee58-925b-4452-bbbb-cdb96dcebcd1"
```



نمایی زیبا و دلربا از فایل terraform.tfstate

باید از قابلیت
Backends

استفاده بکنیم. به این
روش چندین نفر
می‌توانند به این فایل
دسترسی داشته باشند و
همیشه یک نسخه از این
فایل مهم را در باکتهای
خود خواهیم داشت.

```
"image_id": "793cdb82-c731-4aeb-808d-19da98525a02",  
"init_script": null,  
"name": "Terraforms9",  
"networks": [  
  {  
    "ip": "10.255.255.150",  
    "is_public": false,  
    "network_id": "9ad6bd38-a791-481a-be5e-8b09f107fcc0",  
    "port_id": "303779b3-15f0-4aaa-9539-724818b94266",  
    "port_security_enabled": true,  
    "subnet_id": "cd9f8906-c0a8-44fa-af89-18a6294d60ec"  
  }  
],  
"password": "pNxRvPMJeI",  
"region": "ir-thr-bal",  
"revert_to": null,  
"security_groups": [  
  "5f38ee58-925b-4452-bbbb-cdb96dcebcd1"
```

مدیریت secrets در ترا فورم

هارد کدینگ کلیدها یا
تزریق در زمان ارسال درخواست؟

هاردکدینگ کلیدها یا تزریق در زمان ارسال درخواست؟

- **api_key**
- **secret_key**
- **access_key**

استفاده از متغیرها

به صورت

Sensitive = true

استفاده از متغیرها

به صورت

Sensitive = true

اینکار باعث می‌شود که رمزها و موارد حساس در خروجی و لاگ‌های ترافورم redact (غیرقابل مشاهده) بشوند.

The Golden Rule

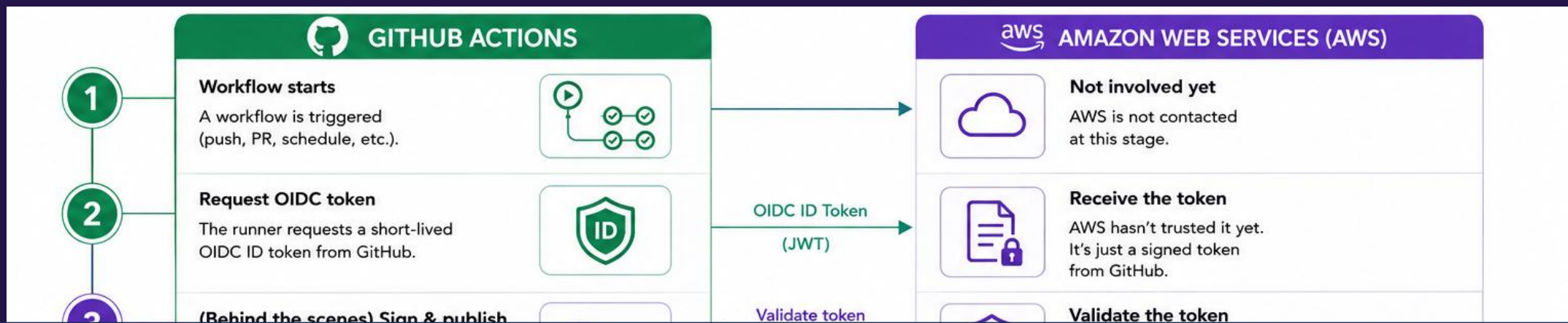
The key should never be written to any file (.tfvars, .tf, ...) It should only ever exist as an in-memory environment variable injected by Vault/Secrets Manager/CI secret store at the moment **terraform apply** runs.

یک روش پیشرفته
OIDC

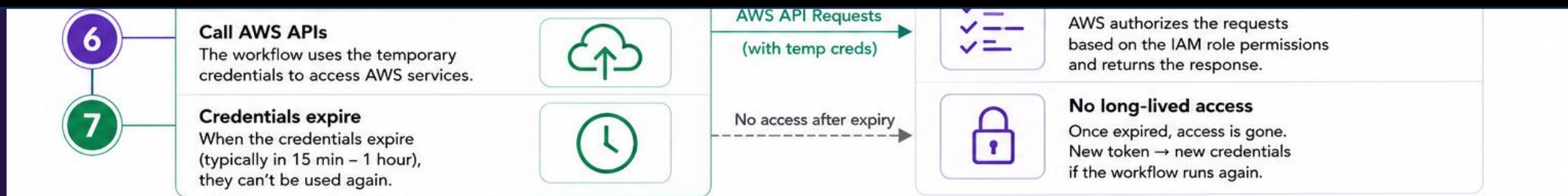
یک روش پیشرفته OIDC

OIDC (OpenID Connect) auth lets Terraform/CI authenticate to Vault (or AWS directly) without any stored secret at all. No token, no static keys sitting in CI variables.

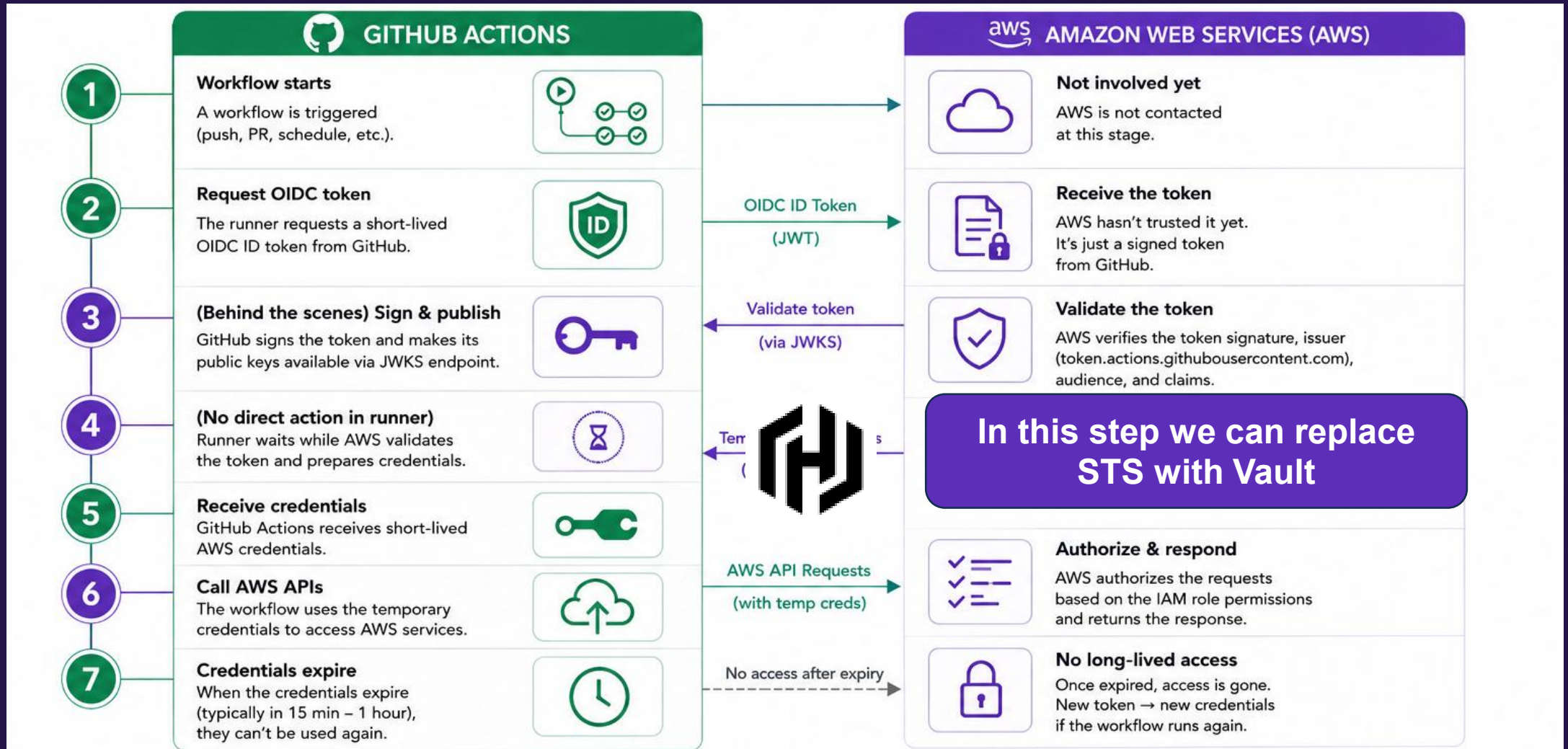
OIDC; for big corps.



کلیت این نمودار این است که هیچ رمز ثابتی در کار نیست و با هر درخواست یک رمز پویا ساخته می‌شود. در نتیجه حمله کنندگان همواره با یک بی‌لاخ مواجه خواهند شد 😊😎



OIDC; for big corps.



بهترین روش ها برای هندل کردن secrets در کار با ترافورم

1. استفاده از OIDC و Vault (بسیار عالی 🙌)
2. استفاده از AWS STS و OIDC (عالی 🙌)
3. استفاده از Vault (بسیار خوب ✅)
4. استفاده از CI Secret Manager (خوب ✅)
5. استفاده از متغیرهای محیطی در زمان اجرای دستور apply در ترافورم (یا به کمک Vault و یا بصورت ساده و export کردن در شل ارسال کننده ی دستور)
(قابل قبول 👍)
6. هاردکد کردن secrets در فایل بعنوان مثال terraform.tfvars (فاجعه 🤡)

حالا بریم برای انجام کار

